

OpenSecure Bank

GRC Compliance Audit Report

NIST Cybersecurity Framework (CSF)

Prepared by: Ninad Patil

Role: GRC Analyst

Tool Used: SimpleRisk

Audit Date: June 22, 2026

Classification: Confidential

Table of Contents

1. Executive Summary
2. Scope and Methodology
3. Asset Inventory Summary
4. Control Maturity Scorecard
5. Gap Analysis Findings
6. Risk Register Summary
7. Remediation Recommendations
8. Conclusion

1. Executive Summary

OpenSecure Bank engaged in a comprehensive GRC compliance audit to assess its cybersecurity posture against the NIST Cybersecurity Framework (CSF). The audit was conducted using SimpleRisk, an enterprise risk management platform, covering five core functions: Identify, Protect, Detect, Respond, and Recover.

The audit evaluated 10 critical assets, 20 security controls, and 10 identified risks across the organization. Of the 20 controls assessed, 5 were found to be non-compliant, representing significant gaps in the bank's detection and response capabilities. Three risks were rated High severity, six were rated Medium, and one was rated Low.

The most critical findings include the absence of a SIEM monitoring platform, lack of Multi-Factor Authentication enforcement on critical systems, and missing Intrusion Detection System coverage across network segments. These gaps expose the bank to significant risk of unauthorized access, data breaches, and undetected cyberattacks.

Immediate remediation is recommended for all High severity findings. A prioritized remediation roadmap is provided in Section 7 of this report.

Key Findings Summary:

Category	Count
Total Assets Inventoried	10
Total Controls Assessed	20
Controls Passing	15
Controls Failing	5
Total Risks Identified	10
High Severity Risks	3
Medium Severity Risks	6
Low Severity Risks	1

2. Scope and Methodology

Audit Scope:

This audit assessed the cybersecurity controls and risk posture of OpenSecure Bank against the NIST Cybersecurity Framework (CSF) version 1.1. The scope included all critical technology assets, security controls, and identified risks across the organization's IT infrastructure, cloud environment, and operational systems.

The following asset categories were included in scope:

- Core banking and database systems
- Network infrastructure including firewall and VPN gateway
- Endpoint devices and employee laptops
- Cloud storage infrastructure (AWS S3)
- ATM network
- Backup and recovery systems
- Internal HR portal and email systems

Methodology:

The audit was conducted using the following approach:

1. **Asset Inventory** — All critical assets were catalogued in SimpleRisk with classification levels, ownership, and valuation assigned to each asset.
2. **Control Mapping** — 20 security controls were mapped to the five NIST CSF functions: Identify, Protect, Detect, Respond, and Recover.
3. **Maturity Scoring** — Each control was scored using a five-level maturity scale from Not Performed to Optimizing to identify current state versus desired state.
4. **Risk Assessment** — 10 risks were identified, scored using the Classic risk scoring method (Likelihood x Impact), and linked to affected assets and controls.
5. **Gap Analysis** — Controls scoring Not Performed or failing status were identified as gaps requiring immediate remediation.
6. **Mitigation Planning** — Mitigation plans were developed for all 10 risks including recommended actions, ownership, and target dates.

7. **Compliance Testing** — Audit tests were defined and initiated for all 5 failing controls within SimpleRisk.

Frameworks and Standards Referenced:

- NIST Cybersecurity Framework (CSF) v1.1
- NIST SP 800-53
- ISO 27001
- CIS Controls v8

3. Asset Inventory Summary

A total of 10 critical assets were identified and catalogued during the audit. Each asset was classified by criticality, assigned to a responsible team, and valued based on business impact.

Asset Name	IP Address	Classification	Team	Valuation
Core Banking Server	10.0.1.10	Critical	IT Systems Management	\$400,001 to \$500,000
Customer Database	10.0.1.20	Critical	Database	\$400,001 to \$500,000
Firewall	10.0.0.1	Critical	Network	\$200,001 to \$300,000
Cloud Storage (AWS S3)	N/A	Critical	IT Systems Management	\$200,001 to \$300,000
ATM Network	10.0.3.0	Critical	Network	\$300,001 to \$400,000
VPN Gateway	10.0.0.2	High	Network	\$100,001 to \$200,000
Email System	10.0.1.30	High	IT Systems Management	\$100,001 to \$200,000
Backup Systems	10.0.1.40	High	Data Center & Storage	\$100,001 to \$200,000
Employee Laptops	10.0.2.0	High	Windows	\$100,001 to \$200,000
Internal HR Portal	10.0.1.50	High	Windows	\$100,001 to \$200,000

- Governance
- Risk Management
- Compliance
- Asset Management**
- Artificial Intelligence
- Assessments
- Reporting

Manage Assets

+

Verified Assets

Unverified Assets

Delete All

10 entries per page

Actions	Asset Name	IP Address	Asset Valuation	Site/Location	Team	Asset Details	Tags
	Asset Name	IP Address	Asset Valuation	Site/Location	Team	Asset Details	Tags
	ATM Network	10.0.3.0	\$300,001 to \$400,000	All Sites	Network	Network of ATM machines processing customer cash withdrawals and deposits. Target for physical and network-based attacks.	Critical

- Governance
- Risk Management
- Compliance
- Asset Management**
- Artificial Intelligence
- Assessments
- Reporting

	Backup Systems	10.0.1.40	\$100,001 to \$200,000	All Sites	Data Center & Storage	Automated backup infrastructure for all critical systems. Essential for recovery in ransomware or disaster scenarios.	High
	Cloud Storage (AWS S3)	N/A	\$200,001 to \$300,000	All Sites	IT Systems Management	AWS S3 buckets storing financial reports, compliance documents, and backup data. Misconfigured bucket policies could lead to public data exposure.	Critical
	Core Banking Server	10.0.1.10	\$400,001 to \$500,000	All Sites	IT Systems Management	Primary server hosting all core banking transactions and customer account data. Critical system requiring 24/7 uptime.	Critical

- Governance
- Risk Management
- Compliance
- Asset Management**
- Artificial Intelligence
- Assessments
- Reporting

	Customer Database	10.0.1.20	\$400,001 to \$500,000	All Sites	Database	Stores all customer PII, account details, and transaction history. Highest sensitivity data asset in the organization.	Critical
	Email System	10.0.1.30	\$100,001 to \$200,000	All Sites	IT Systems Management	Corporate email platform used for all internal and external communications. Primary vector for phishing and social engineering attacks.	High
	Employee Laptops	10.0.2.0	\$100,001 to \$200,000	All Sites	Windows	Endpoint devices used by all bank employees for daily operations. Subject to phishing, malware, and data leakage risks.	High

Asset Icon	Asset Name	IP Address	Asset Valuation	Site/Location	Team	Description	Classification
	Firewall	10.0.0.1	\$200,001 to \$300,000	All Sites	Network	Perimeter firewall, controlling all inbound and outbound traffic across the bank network. First line of defense against external threats.	Critical
	Internal HR Portal	10.0.1.50	\$100,001 to \$200,000	All Sites	Windows	Internal web portal managing employee records, payroll, and HR data. Contains sensitive PII and employment information.	High
	VPN Gateway	10.0.0.2	\$100,001 to \$200,000	All Sites	Network	Provides secure remote access for employees working outside the office. Misconfiguration or compromise could expose the entire internal network.	High

Figure 1: Asset Inventory — Full list of 10 assets catalogued in SimpleRisk Asset Management Module

Asset Classification Summary:

Classification	Count
Critical	5
High	5

Asset Name* Core Banking Server

IP Address 10.0.1.10

Asset Valuation* \$400,001 to \$500,000

Site/Location All Sites

Team IT Systems Management

Asset Details

Primary server hosting all core banking transactions and customer account data. Critical system requiring 24/7 uptime.

Mapped Controls

Current Maturity	Control	Actions
Performed	5 selected	
Documented	RS.RP-1 Incident Response Plan	
Not Performe	RC.IM-1 Lessons Learned Documentation	
Managed	PR.AC-1 Access Control Policy, PR.AC-2 Physical Security Co...	

Tags Critical

Associated Risks [1005] Ransomware Attack on Core Banking Server, [1002] Unpatched Systems ...

Figure 2: Asset Detail View — Core Banking Server showing classification, team, valuation, and asset details

4. Control Maturity Scorecard

A total of 20 security controls were assessed across the five NIST CSF functions. Each control was scored on a maturity scale and assigned a current and desired maturity level.

Maturity Scale:

- **Not Performed** — Control does not exist
- **Performed** — Control exists but is informal
- **Documented** — Control is documented but not measured
- **Managed** — Control is monitored and measured
- **Reviewed** — Control is regularly reviewed
- **Optimizing** — Control is continuously improved

Control ID	Control Name	NIST Function	Current Maturity	Desired Maturity	Status
ID.AM-1	Asset Management Policy	Identify	Performed	Optimizing	Pass
ID.RA-1	Risk Assessment Procedure	Identify	Performed	Optimizing	Pass
ID.SC-1	Third Party Risk Management	Identify	Documented	Optimizing	Pass
PR.AC-1	Access Control Policy	Protect	Managed	Optimizing	Pass
PR.AC-2	Physical Security Controls	Protect	Managed	Optimizing	Pass
PR.AC-7	Multi-Factor Authentication	Protect	Not Performed	Optimizing	Fail
PR.AT-1	Security Awareness Training	Protect	Documented	Optimizing	Pass
PR.DS-1	Data Encryption Standard	Protect	Performed	Optimizing	Pass
PR.IP-1	Patch Management Procedure	Protect	Documented	Optimizing	Pass
DE.AE-1	Anomaly Detection Policy	Detect	Not Performed	Optimizing	Fail
DE.CM-1	SIEM Monitoring	Detect	Not Performed	Optimizing	Fail
DE.CM-3	Log Review Procedure	Detect	Performed	Optimizing	Pass

Control ID	Control Name	NIST Function	Current Maturity	Desired Maturity	Status
DE.CM-4	Intrusion Detection System	Detect	Not Performed	Optimizing	Fail
RS.AN-1	Root Cause Analysis	Respond	Performed	Optimizing	Pass
RS.CO-1	Incident Communication Plan	Respond	Performed	Optimizing	Pass
RS.MI-1	Incident Containment Procedure	Respond	Documented	Optimizing	Pass
RS.RP-1	Incident Response Plan	Respond	Documented	Optimizing	Pass
RC.BP-1	Business Continuity Plan	Recover	Documented	Optimizing	Pass
RC.IM-1	Lessons Learned Documentation	Recover	Not Performed	Optimizing	Fail
RC.RP-1	Backup and Recovery Plan	Recover	Managed	Optimizing	Pass

SimpleRisk

?
⚙️
👤

Governance
Define Control Frameworks
Document Program
Define Exceptions
Risk Management
Compliance
Asset Management
Artificial Intelligence
Assessments
Reporting

Define Control Frameworks

Frameworks(1)
Controls(20)

Filters

Control Class:

ALL (4)

Control Phase:

ALL (4)

Control Family:

Unassigned

Control Owner:

ALL (2)

Control Framework:

ALL (2)

Control Priority:

ALL (3)

Control Type:

ALL (4)

Control Status:

ALL (2)

Filter by Text:

25 entries per page

☐ Select All
Delete Selected Controls
Create Control

Control ID :

1001

Control Short Name :

ID.AM-1 Asset Management Policy

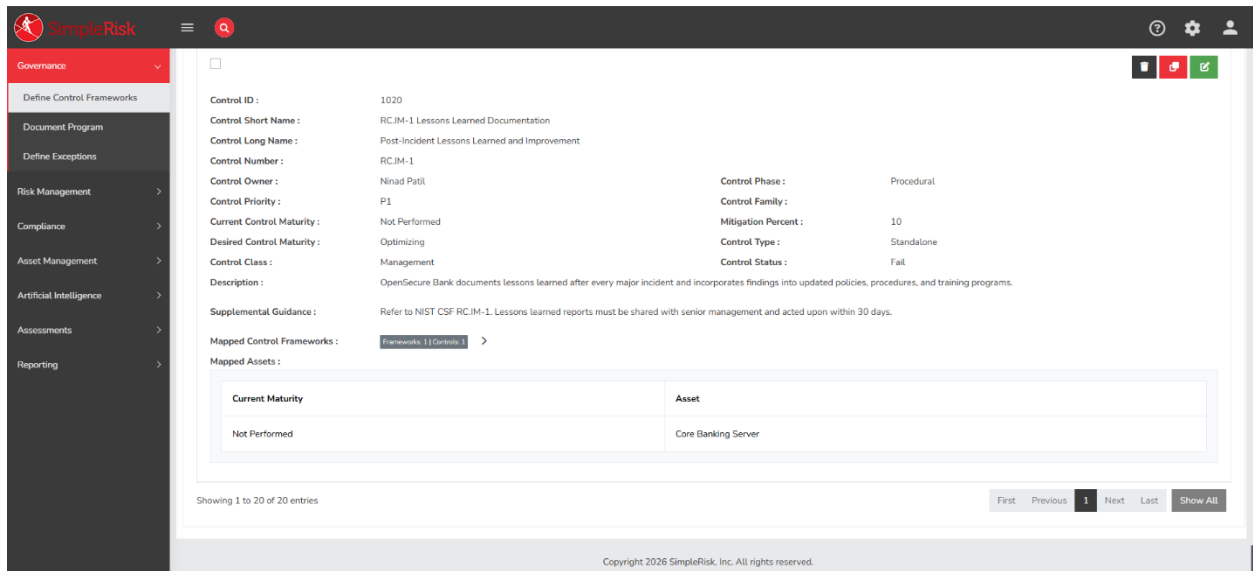
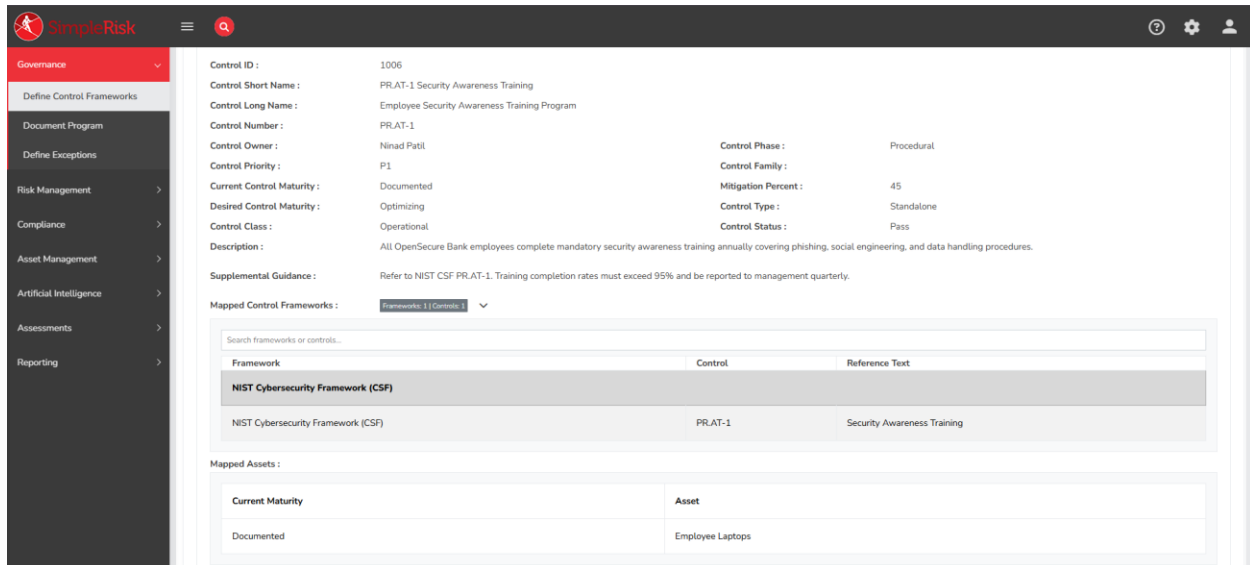


Figure 3: Control Framework — All 20 NIST CSF controls mapped in SimpleRisk Governance Module

Control Status Summary:

NIST Function	Total Controls	Passing	Failing
Identify	3	3	0
Protect	6	5	1
Detect	4	1	3
Respond	4	4	0
Recover	3	2	1
Total	20	15	5



Control ID : 1006

Control Short Name : PR.AT-1 Security Awareness Training

Control Long Name : Employee Security Awareness Training Program

Control Number : PR.AT-1

Control Owner : Ninad Patil

Control Phase : Procedural

Control Priority : P1

Control Family :

Current Control Maturity : Documented

Mitigation Percent : 45

Desired Control Maturity : Optimizing

Control Type : Standalone

Control Class : Operational

Control Status : Pass

Description : All OpenSecure Bank employees complete mandatory security awareness training annually covering phishing, social engineering, and data handling procedures.

Supplemental Guidance : Refer to NIST CSF PR.AT-1. Training completion rates must exceed 95% and be reported to management quarterly.

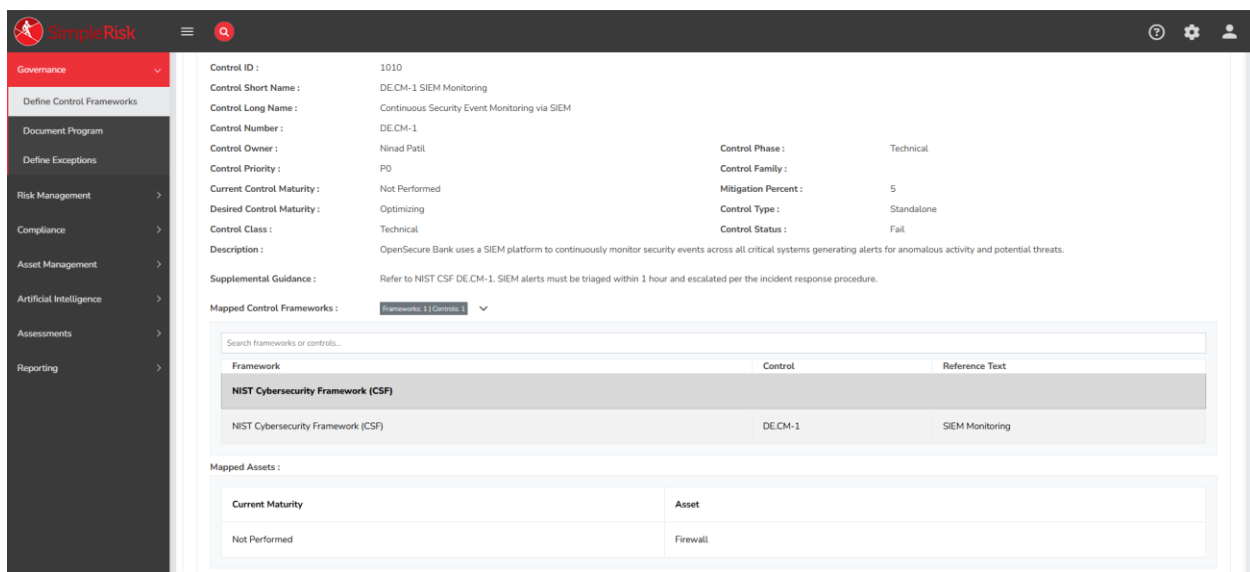
Mapped Control Frameworks : Frameworks: 1 | Controls: 1

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	PR.AT-1	Security Awareness Training

Mapped Assets :

Current Maturity	Asset
Documented	Employee Laptops

Figure 4: Control Detail View — PR.AT-1 Employee Security Awareness Training showing maturity scores, mapped framework, and mapped assets



Control ID : 1010

Control Short Name : DE.CM-1 SIEM Monitoring

Control Long Name : Continuous Security Event Monitoring via SIEM

Control Number : DE.CM-1

Control Owner : Ninad Patil

Control Phase : Technical

Control Priority : P0

Control Family :

Current Control Maturity : Not Performed

Mitigation Percent : 5

Desired Control Maturity : Optimizing

Control Type : Standalone

Control Class : Technical

Control Status : Fail

Description : OpenSecure Bank uses a SIEM platform to continuously monitor security events across all critical systems generating alerts for anomalous activity and potential threats.

Supplemental Guidance : Refer to NIST CSF DE.CM-1. SIEM alerts must be triaged within 1 hour and escalated per the incident response procedure.

Mapped Control Frameworks : Frameworks: 1 | Controls: 1

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	DE.CM-1	SIEM Monitoring

Mapped Assets :

Current Maturity	Asset
Not Performed	Firewall

Figure 5: Control Detail View — DE.CM-1 SIEM Monitoring showing Not Performed maturity and Fail status

5. Gap Analysis Findings

The gap analysis identified 5 controls that are currently non-compliant with NIST CSF requirements. These controls represent the highest priority remediation items for OpenSecure Bank.

GAP 1 — DE.CM-1 SIEM Monitoring

NIST Function: Detect

Current Maturity: Not Performed

Risk Exposure: Critical

Finding: OpenSecure Bank does not have a SIEM platform deployed. Security events across critical systems including the core banking server, customer database, and firewall are not being centrally monitored or correlated. This means active threats and intrusions could go undetected indefinitely.

Business Impact: Without SIEM monitoring the bank cannot detect ransomware, unauthorized access, or data exfiltration in real time. This directly violates NIST CSF DE.CM-1 requirements and exposes the bank to significant regulatory and financial risk.

GAP 2 — PR.AC-7 Multi-Factor Authentication

NIST Function: Protect

Current Maturity: Not Performed

Risk Exposure: Critical

Finding: Multi-Factor Authentication is not enforced on privileged accounts, remote access connections, or critical system logins including the customer database and VPN gateway. Single-factor authentication significantly increases the risk of credential-based attacks.

Business Impact: Compromised credentials without MFA protection provide attackers unrestricted access to critical banking systems and sensitive customer data.

GAP 3 — DE.CM-4 Intrusion Detection System

NIST Function: Detect

Current Maturity: Not Performed

Risk Exposure: Critical

Finding: No IDS/IPS solution is deployed across OpenSecure Bank network segments. Malicious network traffic including port scanning, lateral movement, and exploitation attempts are not being detected or blocked in real time.

Business Impact: Without IDS coverage the bank has no visibility into network-based attacks. Threat actors could move laterally across the network undetected for extended periods.

GAP 4 — DE.AE-1 Anomaly Detection Policy

NIST Function: Detect

Current Maturity: Not Performed

Risk Exposure: Critical

Finding: No behavioral baselines have been established for network traffic or user activity. Without baselines anomalous behavior such as unusual login times, large data transfers, or access to restricted resources cannot be detected automatically.

Business Impact: Insider threats and advanced persistent threats rely on blending into normal activity patterns. Without anomaly detection these threats cannot be identified until significant damage has occurred.

GAP 5 — RC.IM-1 Lessons Learned Documentation

NIST Function: Recover

Current Maturity: Not Performed

Risk Exposure: High

Finding: OpenSecure Bank does not have a formal lessons learned process following security incidents. Without post-incident analysis the bank cannot identify root causes, improve controls, or prevent recurrence of similar incidents.

Business Impact: Repeated security incidents due to unaddressed root causes increase operational costs, regulatory scrutiny, and reputational damage over time.

The screenshot displays the SimpleRisk web application interface. The top navigation bar includes the SimpleRisk logo, a search icon, and user settings. The left sidebar lists various modules: Governance, Define Control Frameworks, Document Program, Define Exceptions, Risk Management, Compliance, Asset Management, Artificial Intelligence, Assessments, and Reporting. The main content area is titled 'Define Control Frameworks' and shows a list of frameworks and controls. The 'Controls(5)' tab is active. Below the tabs, there are filters for Control Class, Control Phase, Control Family, Control Owner, Control Framework, Control Priority, Control Type, Control Status, and a text filter. The 'Control Status' filter is set to 'Fail'. At the bottom, there is a pagination control showing '10 entries per page' and buttons for 'Select All', 'Delete Selected Controls', and 'Create Control'.

Governance

Define Control Frameworks

Document Program

Define Exceptions

Risk Management

Compliance

Asset Management

Artificial Intelligence

Assessments

Reporting

Control ID :

1005

Control Short Name :

PRAC-7 Multi-Factor Authentication

Control Long Name :

Multi-Factor Authentication for Critical Systems

Control Number :

PRAC-7

Control Owner :

Ninad Patil

Control Priority :

P0

Current Control Maturity :

Not Performed

Desired Control Maturity :

Optimizing

Control Class :

Technical

Description :

MFA is enforced for all privileged accounts and remote access to OpenSecure Bank critical systems including core banking and customer database.

Supplemental Guidance :

Refer to NIST CSF PRAC-7, MFA enforcement must be validated monthly via access logs.

Control Phase :

Technical

Control Family :

Mitigation Percent :

10

Control Type :

Standalone

Control Status :

Fail

Mapped Control Frameworks :

Frameworks: 1 | Control: 1

Search frameworks or controls...

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	PRAC-7	Multi-Factor Authentication

Mapped Assets :

Current Maturity	Asset
Not Performed	VPN Gateway

Governance

Define Control Frameworks

Document Program

Define Exceptions

Risk Management

Compliance

Asset Management

Artificial Intelligence

Assessments

Reporting

Control ID :

1010

Control Short Name :

DECM-1 SIEM Monitoring

Control Long Name :

Continuous Security Event Monitoring via SIEM

Control Number :

DECM-1

Control Owner :

Ninad Patil

Control Priority :

P0

Current Control Maturity :

Not Performed

Desired Control Maturity :

Optimizing

Control Class :

Technical

Description :

OpenSecure Bank uses a SIEM platform to continuously monitor security events across all critical systems generating alerts for anomalous activity and potential threats.

Supplemental Guidance :

Refer to NIST CSF DECM-1, SIEM alerts must be triaged within 1 hour and escalated per the incident response procedure.

Control Phase :

Technical

Control Family :

Mitigation Percent :

5

Control Type :

Standalone

Control Status :

Fail

Mapped Control Frameworks :

Frameworks: 1 | Control: 1

Search frameworks or controls...

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	DECM-1	SIEM Monitoring

Mapped Assets :

Current Maturity	Asset
Not Performed	Firewall

Governance

Define Control Frameworks

Document Program

Define Exceptions

Risk Management

Compliance

Asset Management

Artificial Intelligence

Assessments

Reporting

Control ID :

1011

Control Short Name :

DECM-4 Intrusion Detection System

Control Long Name :

Network Intrusion Detection and Prevention

Control Number :

DECM-4

Control Owner :

Ninad Patil

Control Priority :

P0

Current Control Maturity :

Not Performed

Desired Control Maturity :

Optimizing

Control Class :

Technical

Description :

OpenSecure Bank deploys IDS/IPS solutions to monitor network traffic for malicious activity and block threats in real time across all network segments.

Supplemental Guidance :

Refer to NIST CSF DECM-4, IDS signatures must be updated weekly and detection coverage reviewed monthly.

Control Phase :

Technical

Control Family :

Mitigation Percent :

5

Control Type :

Standalone

Control Status :

Fail

Mapped Control Frameworks :

Frameworks: 1 | Control: 1

Search frameworks or controls...

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	DECM-4	Intrusion Detection System

Mapped Assets :

Current Maturity	Asset
Not Performed	Firewall

Governance

Define Control Frameworks

Document Program

Define Exceptions

Risk Management

Compliance

Asset Management

Artificial Intelligence

Assessments

Reporting

Control ID :

Control Short Name :

Control Long Name :

Control Number :

Control Owner :

Control Priority :

Current Control Maturity :

Desired Control Maturity :

Control Class :

Description :

Supplemental Guidance :

Mapped Control Frameworks :

1013

DE-AE-1 Anomaly Detection Policy

Security Anomaly Detection and Alerting

DE-AE-1

Ninad Patil

P0

Not Performed

Optimizing

Technical

Baseline network and user behavior is established and monitored. Deviations from baseline trigger automated alerts for investigation by the security team.

Refer to NIST CSF DE-AE-1. Baselines must be reviewed quarterly and updated to reflect changes in normal behavior.

Framework 1 | Controls 1

Control Phase :

Control Family :

Mitigation Percent :

Control Type :

Control Status :

Technical

5

Standalone

Fail

Search frameworks or controls...

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	DE-AE-1	Anomaly Detection Policy

Mapped Assets :

Current Maturity	Asset
Not Performed	Firewall

Governance

Define Control Frameworks

Document Program

Define Exceptions

Risk Management

Compliance

Asset Management

Artificial Intelligence

Assessments

Reporting

Control ID :

Control Short Name :

Control Long Name :

Control Number :

Control Owner :

Control Priority :

Current Control Maturity :

Desired Control Maturity :

Control Class :

Description :

Supplemental Guidance :

Mapped Control Frameworks :

1020

RC.IM-1 Lessons Learned Documentation

Post-Incident Lessons Learned and Improvement

RC.IM-1

Ninad Patil

P1

Not Performed

Optimizing

Management

OpenSecure Bank documents lessons learned after every major incident and incorporates findings into updated policies, procedures, and training programs.

Refer to NIST CSF RC.IM-1. Lessons learned reports must be shared with senior management and acted upon within 30 days.

Framework 1 | Controls 1

Control Phase :

Control Family :

Mitigation Percent :

Control Type :

Control Status :

Procedural

10

Standalone

Fail

Search frameworks or controls...

Framework	Control	Reference Text
NIST Cybersecurity Framework (CSF)		
NIST Cybersecurity Framework (CSF)	RC.IM-1	Lessons Learned Documentation

Mapped Assets :

Current Maturity	Asset
Not Performed	Core Banking Server

Figure 6: Gap Analysis — Controls filtered by Status: Fail showing 5 non-compliant controls

- Governance
- Risk Management
- Compliance
- Define Tests
- Initiate Audits
- Active Audits
- Past Audits
- Asset Management
- Artificial Intelligence
- Assessments
- Reporting

Initiate Audits

Filter by Text :

Test Frequency :

Framework :

NIST Cybersecurity Framework (CSF)

Control :

Name	Test Frequency	Last Audit Date	Next Audit Date	Status	
NIST Cybersecurity Framework (CSF)				Active	Initiate Framework Audit
- PI.AC-7 Multi-Factor Authentication				Active	Initiate Control Audit
MFA Enforcement Validation Test	90	06/22/2026	09/20/2026	Active	Initiate Test
DE.CM-1 SIEM Monitoring				Active	Initiate Control Audit
SIEM Deployment and Alert Validation Test	90	06/22/2026	09/20/2026	Active	Initiate Test
DE.CM-4 Intrusion Detection System				Active	Initiate Control Audit
IDS Coverage and Signature Validation Test	90	06/22/2026	09/20/2026	Active	Initiate Test
DE.AE-1 Anomaly Detection Policy				Active	Initiate Control Audit
Baseline Behavior and Anomaly Alert Test	90	06/22/2026	09/20/2026	Active	Initiate Test
RC.IM-1 Lessons Learned Documentation				Active	Initiate Control Audit
Post Incident Lessons Learned Review Test	180	06/22/2026	12/18/2026	Active	Initiate Test

Figure 7: Initiate Audits — All 5 failing controls mapped to NIST CSF framework ready for audit

6. Risk Register Summary

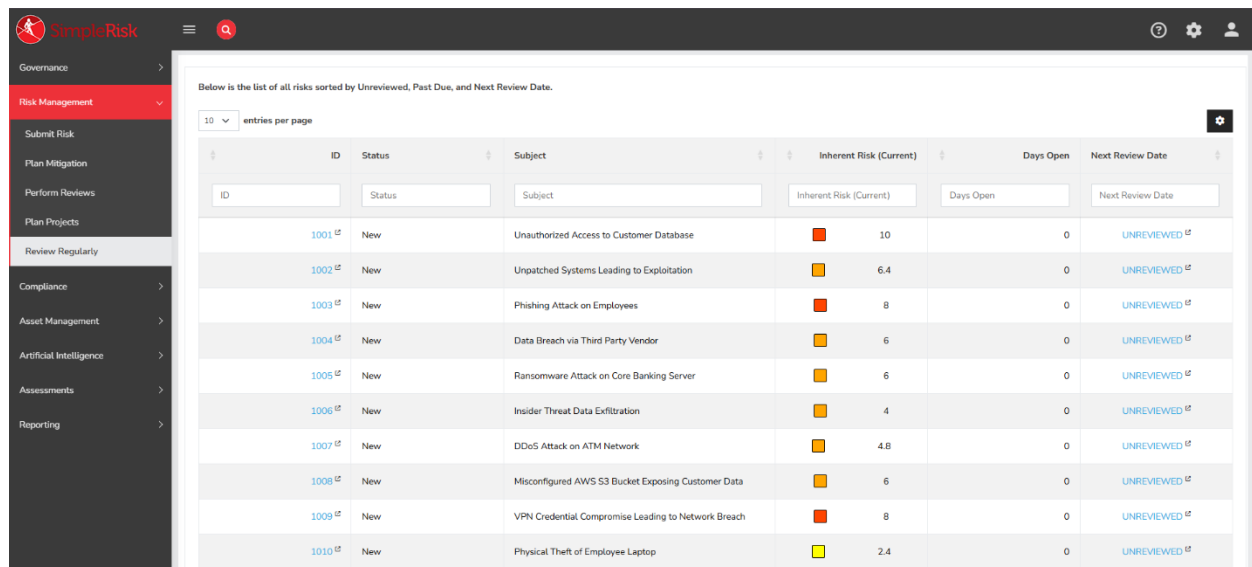
A total of 10 risks were identified, assessed, and documented in SimpleRisk during this audit. Risks were scored using the Classic scoring method where Risk Score equals Likelihood multiplied by Impact divided by 2.5.

Risk Scoring Scale:

- **8 to 10 — High:** Immediate action required
- **4 to 7.9 — Medium:** Action required within 90 days
- **0 to 3.9 — Low:** Monitor and review annually

Risk ID	Risk Description	Affected Asset	Likelihood	Impact	Risk Score	Priority
RISK-001	Unauthorized Access to Customer Database	Customer Database	Almost Certain	Extreme/Catastrophic	10	High
RISK-003	Phishing Attack on Employees	Employee Laptops	Almost Certain	Major	8	High
RISK-009	VPN Credential Compromise	VPN Gateway	Likely	Extreme/Catastrophic	8	High
RISK-002	Unpatched Systems Leading to Exploitation	Core Banking Server	Likely	Major	6.4	Medium
RISK-004	Data Breach via Third Party Vendor	Customer Database	Credible	Extreme/Catastrophic	6	Medium
RISK-005	Ransomware on Core Banking Server	Core Banking Server	Credible	Extreme/Catastrophic	6	Medium
RISK-008	Misconfigured AWS S3 Bucket	Cloud Storage	Credible	Extreme/Catastrophic	6	Medium

Risk ID	Risk Description	Affected Asset	Likelihood	Impact	Risk Score	Priority
RISK-007	DDoS Attack on ATM Network	ATM Network	Credible	Major	4.8	Medium
RISK-006	Insider Threat Data Exfiltration	Customer Database	Unlikely	Extreme/Catastrophic	4	Medium
RISK-010	Physical Theft of Employee Laptop	Employee Laptops	Unlikely	Moderate	2.4	Low



Below is the list of all risks sorted by Unreviewed, Past Due, and Next Review Date.

ID	Status	Subject	Inherent Risk (Current)	Days Open	Next Review Date
1001	New	Unauthorized Access to Customer Database	10	0	UNREVIEWED
1002	New	Unpatched Systems Leading to Exploitation	6.4	0	UNREVIEWED
1003	New	Phishing Attack on Employees	8	0	UNREVIEWED
1004	New	Data Breach via Third Party Vendor	6	0	UNREVIEWED
1005	New	Ransomware Attack on Core Banking Server	6	0	UNREVIEWED
1006	New	Insider Threat Data Exfiltration	4	0	UNREVIEWED
1007	New	DDoS Attack on ATM Network	4.8	0	UNREVIEWED
1008	New	Misconfigured AWS S3 Bucket Exposing Customer Data	6	0	UNREVIEWED
1009	New	VPN Credential Compromise Leading to Network Breach	8	0	UNREVIEWED
1010	New	Physical Theft of Employee Laptop	2.4	0	UNREVIEWED

Figure 8: Risk Register — Full list of 10 risks sorted by Inherent Risk score in SimpleRisk

Risk Distribution Summary:

Risk Level	Count	Percentage
High	3	30%
Medium	6	60%
Low	1	10%

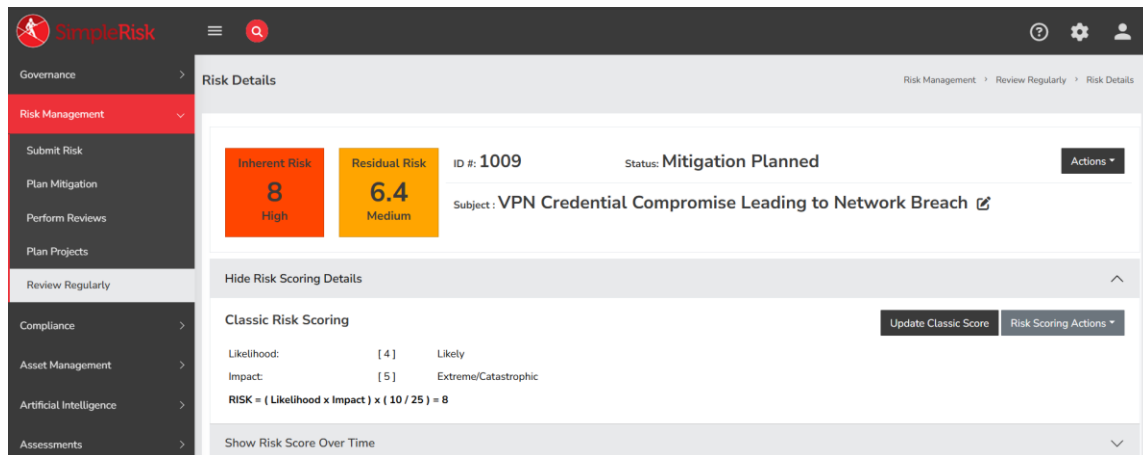


Figure 9: Risk Scoring — Classic risk scoring breakdown showing Likelihood, Impact, and calculated score

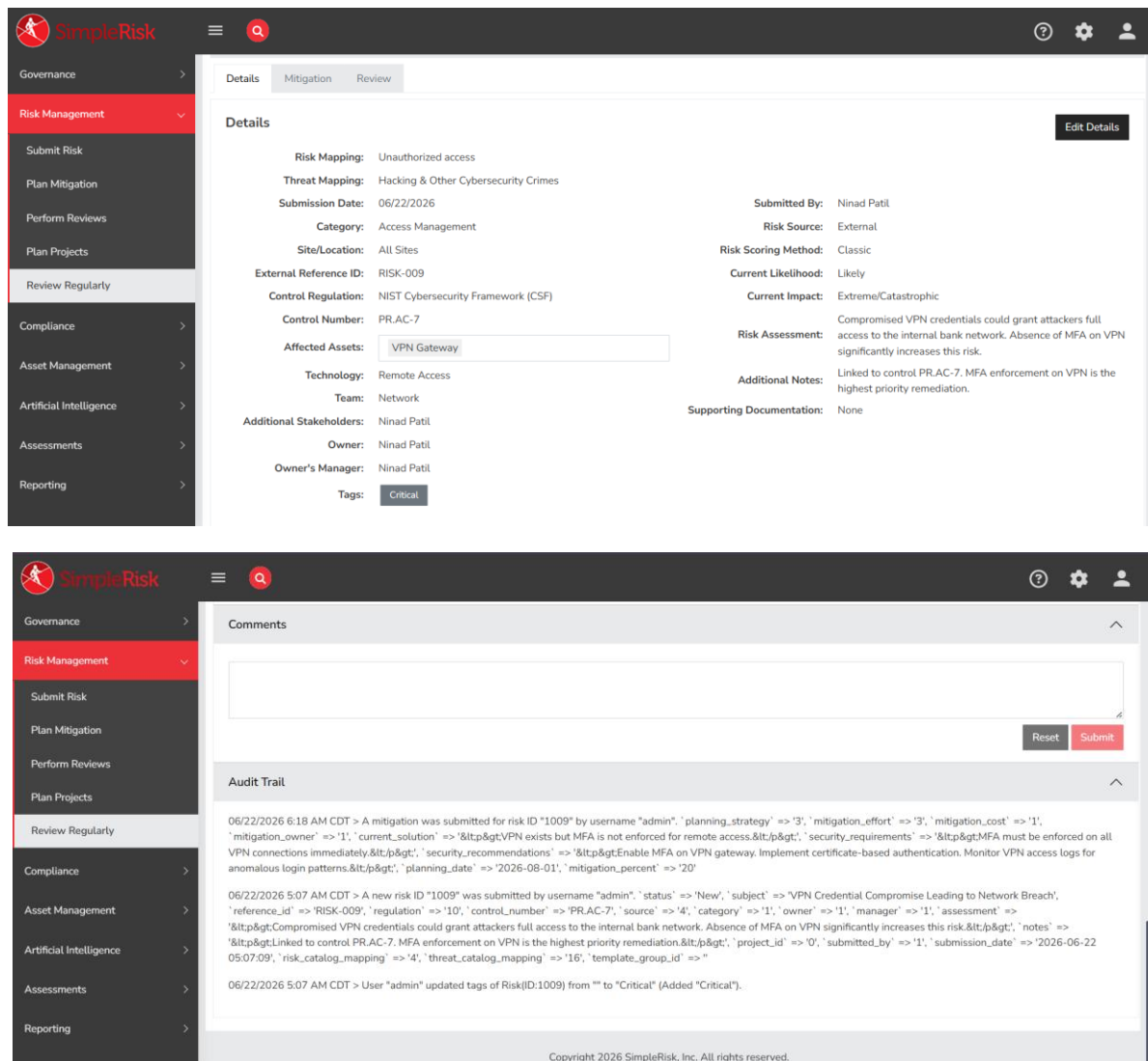


Figure 10: Risk Detail View — RISK-009 Unauthorized Access to Network using compromised VPN credentials showing score, details, and audit trail

7. Remediation Recommendations

Based on the gap analysis and risk assessment findings, the following remediation actions are recommended in order of priority.

Priority 1 — Immediate Action Required (0 to 30 days):

Control	Recommendation	Owner	Target Date
DE.CM-1 SIEM Monitoring	Deploy SIEM platform and connect all critical log sources including firewall, core banking server, and customer database	IT Systems Management	July 22, 2026
PR.AC-7 Multi-Factor Authentication	Enforce MFA on all privileged accounts, VPN gateway, and critical system access immediately	IT Systems Management	July 22, 2026
DE.CM-4 Intrusion Detection System	Deploy IDS/IPS across all network segments and configure alerting	Network	July 22, 2026

Priority 2 — Short Term Action Required (30 to 90 days):

Control	Recommendation	Owner	Target Date
DE.AE-1 Anomaly Detection Policy	Establish network and user behavior baselines and configure anomaly detection rules in SIEM	IT Systems Management	September 22, 2026
PR.IP-1 Patch Management	Implement automated patch management and enforce 72 hour critical patch window	IT Systems Management	September 22, 2026
PR.AT-1 Security Awareness Training	Launch quarterly phishing simulations and increase training frequency	IT Systems Management	September 22, 2026

Priority 3 — Medium Term Action Required (90 to 180 days):

Control	Recommendation	Owner	Target Date
RC.IM-1 Lessons Learned	Establish formal post-incident lessons learned process and reporting to senior management	IT Systems Management	December 22, 2026
ID.SC-1 Third Party Risk	Formalize vendor security assessment process and include security requirements in all contracts	IT Systems Management	December 22, 2026

Overall Risk Remediation Priority:

Risk	Current Score	Target Score	Remediation Action
Unauthorized Access to Customer Database	10	4	Implement MFA and quarterly access reviews
Phishing Attack on Employees	8	3	Launch phishing simulations and email filtering
VPN Credential Compromise	8	3	Enforce MFA on VPN immediately
Unpatched Systems	6.4	2	Automate patch management
Ransomware on Core Banking Server	6	2	Deploy SIEM and verify backup recovery

Governance

Risk Management

Submit Risk

Plan Mitigation

Perform Reviews

Plan Projects

Review Regularly

Compliance

Asset Management

Artificial Intelligence

Assessments

Reporting

Below is the list of submitted risks that require a management review.

10

entries per page

ID	Status	Subject	Inherent Risk (Current)	Submission Date	Mitigation Planned	Management Review
ID	Status	Subject	Inherent Risk (Current)	Submission Date	--	--
1001	Mitigation Planned	Unauthorized Access to Customer Database	10	06/22/2026 3:59 AM CDT	Yes	No
1003	Mitigation Planned	Phishing Attack on Employees	8	06/22/2026 4:25 AM CDT	Yes	No
1009	Mitigation Planned	VPN Credential Compromise Leading to Network Breach	8	06/22/2026 5:07 AM CDT	Yes	No
1002	Mitigation Planned	Unpatched Systems Leading to Exploitation	6.4	06/22/2026 4:18 AM CDT	Yes	No
1004	Mitigation Planned	Data Breach via Third Party Vendor	6	06/22/2026 4:30 AM CDT	Yes	No
1005	Mitigation Planned	Ransomware Attack on Core Banking Server	6	06/22/2026 4:33 AM CDT	Yes	No
1008	Mitigation Planned	Misconfigured AWS S3 Bucket Exposing Customer Data	6	06/22/2026 5:03 AM CDT	Yes	No
1007	Mitigation Planned	DDoS Attack on ATM Network	4.8	06/22/2026 4:58 AM CDT	Yes	No
1006	Mitigation Planned	Insider Threat Data Exfiltration	4	06/22/2026 4:55 AM CDT	Yes	No
1010	Mitigation Planned	Physical Theft of Employee Laptop	2.4	06/22/2026 5:09 AM CDT	Yes	No

Showing 1 to 10 of 10 entries

First

Previous

1

Next

Last

Show All

Figure 11: Mitigation Plans — All 10 risks showing Mitigation Planned status in SimpleRisk

PR.AC-7 PR.AC-7 Multi-Factor Authentication Add Test											
Control Long Name :		Multi-Factor Authentication for Critical Systems									
Control Owner :		Ninad Patil									
Description :		MFA is enforced for all privileged accounts and remote access to OpenSecure Bank critical systems including core banking and customer database.									
Mapped Control Frameworks :		Frameworks: 1 Controls: 1									
ID	Test Name	Tester	Additional Stakeholders	Tags	Test Frequency	Last Test Date	Next Test Date	Automatically Initiate Audit	Audit Initiation Offset	Approximate Time	Actions
2	MFA Enforcement Validation Test	Ninad Patil	Ninad Patil	Critical	90 days	06/22/2026	09/20/2026	No	--	60 minutes	

DE.CM-1 DE.CM-1 SIEM Monitoring Add Test											
Control Long Name :		Continuous Security Event Monitoring via SIEM									
Control Owner :		Ninad Patil									
Description :		OpenSecure Bank uses a SIEM platform to continuously monitor security events across all critical systems generating alerts for anomalous activity and potential threats.									
Mapped Control Frameworks :		Frameworks: 1 Controls: 1									
ID	Test Name	Tester	Additional Stakeholders	Tags	Test Frequency	Last Test Date	Next Test Date	Automatically Initiate Audit	Audit Initiation Offset	Approximate Time	Actions
1	SIEM Deployment and Alert Validation Test	Ninad Patil	Ninad Patil	Critical	90 days	06/22/2026	09/20/2026	No	--	120 minutes	

Showing 1 to 10 of 20 entries

First Previous 1 2 Next Last Show All

DE.CM-4 DE.CM-4 Intrusion Detection System Add Test											
Control Long Name :		Network Intrusion Detection and Prevention									
Control Owner :		Ninad Patil									
Description :		OpenSecure Bank deploys IDS/IPS solutions to monitor network traffic for malicious activity and block threats in real time across all network segments.									
Mapped Control Frameworks :		Frameworks: 1 Controls: 1									
ID	Test Name	Tester	Additional Stakeholders	Tags	Test Frequency	Last Test Date	Next Test Date	Automatically Initiate Audit	Audit Initiation Offset	Approximate Time	Actions
4	IDS Coverage and Signature Validation Test	Ninad Patil	Ninad Patil	Critical	90 days	06/22/2026	09/20/2026	No	--	90 minutes	

DE.AE-1 DE.AE-1 Anomaly Detection Policy Add Test											
Control Long Name :		Security Anomaly Detection and Alerting									
Control Owner :		Ninad Patil									
Description :		Baseline network and user behavior is established and monitored. Deviations from baseline trigger automated alerts for investigation by the security team.									
Mapped Control Frameworks :		Framework: 1 Control: 1 >									
ID	Test Name	Tester	Additional Stakeholders	Tags	Test Frequency	Last Test Date	Next Test Date	Automatically Initiate Audit	Audit Initiation Offset	Approximate Time	Actions
5	Baseline Behavior and Anomaly Alert Test	Ninad Patil	Ninad Patil	Critical	90 days	06/22/2026	09/20/2026	No	--	90 minutes	 

RC.IM-1 RC.IM-1 Lessons Learned Documentation Add Test											
Control Long Name :		Post-Incident Lessons Learned and Improvement									
Control Owner :		Ninad Patil									
Description :		OpenSecure Bank documents lessons learned after every major incident and incorporates findings into updated policies, procedures, and training programs.									
Mapped Control Frameworks :		Framework: 1 Control: 1 >									
ID	Test Name	Tester	Additional Stakeholders	Tags	Test Frequency	Last Test Date	Next Test Date	Automatically Initiate Audit	Audit Initiation Offset	Approximate Time	Actions
6	Post-Incident Lessons Learned Review Test	Ninad Patil	Ninad Patil	Critical	180 days	06/22/2026	12/18/2026	No	--	60 minutes	 

Showing 11 to 20 of 20 entries

First
Previous
1
2
Next
Last
Show All

Figure 12: Compliance Tests — Define Tests page showing audit tests created for all 5 failing controls



Governance

Risk Management

Submit Risk

Plan Mitigation

Perform Reviews

Plan Projects

Review Regularly

Compliance

Asset Management

Artificial Intelligence

Assessments

Risk Details

Inherent Risk

10

High

Residual Risk

8

High

ID #: 1001
Status: Mitigation Planned

Actions

Subject: Unauthorized Access to Customer Database

Hide Risk Scoring Details

Classic Risk Scoring

Likelihood:

[5]

Almost Certain

Impact:

[5]

Extreme/Catastrophic

RISK = (Likelihood x Impact) x (10 / 25) = 10

Show Risk Score Over Time



Governance

Risk Management

Submit Risk

Plan Mitigation

Perform Reviews

Plan Projects

Review Regularly

Compliance

Asset Management

Details Mitigation Review

Mitigation

Mitigation Submission Date:

06/22/2026

Planned Mitigation Date:

09/22/2026

Planning Strategy:

Mitigate

Mitigation Effort:

Significant

Mitigation Cost:

\$100,001 to \$200,000

Mitigation Owner:

Ninad Patil

Mitigation Team:

Database

Mitigation Percent:

20

Accept Mitigation

Current Solution:

Basic access controls exist but MFA is not enforced on database access.

Security Requirements:

MFA must be enforced on all database access. Quarterly access reviews required.

Security Recommendations:

Implement MFA on Customer Database immediately. Review and revoke unnecessary database privileges.

Supporting Documentation:

None

Edit Mitigation

The screenshot displays the 'Mitigation Controls' section of the SimpleRisk application. The left sidebar shows navigation options: Governance, Risk Management (selected), Submit Risk, Plan Mitigation, Perform Reviews, Plan Projects, Review Regularly, Compliance, Asset Management, Artificial Intelligence, Assessments, and Reporting.

The main content area shows two control entries. The first entry, RISK-001, has the following details:

- Control Long Name:** Identity and Access Management Policy
- Control Short Name:** PRAC-1 Access Control Policy
- Control Class:** Technical
- Control Phase:** Technical
- Control Owner:** Ninad Patil
- Control Number:** PRAC-1
- Control Priority:** PO
- Control Family:** Mitigation Percent: 60%
- Description:** Access to OpenSecure Bank systems is granted on a least privilege basis. All user accounts are reviewed quarterly and terminated upon employee offboarding.
- Supplemental Guidance:** Refer to NIST CSF PRAC-1. Access reviews must be documented and approved by department heads.
- Mapped Control Frameworks:** Frameworks: 1 Control: 1

The second entry, RISK-002, has the following details:

- Control Long Name:** Multi-Factor Authentication for Critical Systems
- Control Short Name:** PRAC-7 Multi-Factor Authentication
- Control Class:** Technical
- Control Phase:** Technical
- Control Owner:** Ninad Patil
- Control Number:** PRAC-7
- Control Priority:** PO
- Control Family:** Mitigation Percent: 10%
- Description:** MFA is enforced for all privileged accounts and remote access to OpenSecure Bank critical systems including core banking and customer database.
- Supplemental Guidance:** Refer to NIST CSF PRAC-7. MFA enforcement must be validated monthly via access logs.
- Mapped Control Frameworks:** Frameworks: 1 Control: 1

At the bottom, it shows 'Showing 1 to 2 of 2 entries' and navigation buttons: First, Previous, 1, Next, Last, Show All.

Figure 13: Mitigation Detail — RISK-001 showing complete mitigation plan including strategy, effort, cost, and recommendations

The screenshot displays the 'Active Audits' section of the SimpleRisk application. The left sidebar shows navigation options: Governance, Risk Management, Compliance (selected), Define Tests, Define Audits, Active Audits, Past Audits, Asset Management, Artificial Intelligence, Assessments, and Reporting.

The main content area shows a table of active audits. The table has the following columns: Test Name, Test Frequency, Tester, Additional Stakeholders, Team(s), Objective, Control Name, Framework Name, Tags, Status, Test Date, Last Audit Date, Next Audit Date, Test Result, and Actions.

Test Name	Test Frequency	Tester	Additional Stakeholders	Team(s)	Objective	Control Name	Framework Name	Tags	Status	Test Date	Last Audit Date	Next Audit Date	Test Result	Actions
Executive Behavior and Anomaly Alert Test	90 days	Ninad Patil	Ninad Patil	IT Systems Management	Verify that network and user behavior baselines are established and anomaly detection alerts are configured and active.	DE-AC-1 Anomaly Detection Policy	NIST Cybersecurity Framework (CSF)	MIT CSF 2020-2021 Audit	Active		06/22/2024	06/22/2024		Details
IDS Coverage and Signature Validation Test	90 days	Ninad Patil	Ninad Patil	Network	Verify that IDS/IPS solutions are deployed across all network segments and signatures are current.	DE-CM-4 Intrusion Detection System	NIST Cybersecurity Framework (CSF)	MIT CSF 2020-2021 Audit	Active		06/22/2024	06/22/2024		Details
MFA Enforcement Validation Test	90 days	Ninad Patil	Ninad Patil	IT Systems Management	Verify that MFA is enforced on all privileged accounts and remote access connections to critical systems.	PRAC-7 Multi-Factor Authentication	NIST Cybersecurity Framework (CSF)	MIT CSF 2020-2021 Audit	Active		06/22/2024	06/22/2024		Details
Phish Incident Lessons Learned Review Test	180 days	Ninad Patil	Ninad Patil	IT Systems Management	Verify that lessons learned documentation exists for past incidents and findings have been incorporated into updated policies and procedures.	DE-IR-3 Lessons Learned Documentation	NIST Cybersecurity Framework (CSF)	MIT CSF 2020-2021 Audit	Active		06/22/2024	12/08/2024		Details
SDM Deployment and Alert Validation Test	90 days	Ninad Patil	Ninad Patil	IT Systems Management	Verify that a SDM platform is deployed, configured, and generating alerts for security events across all critical systems.	DE-CM-1 SDM Monitoring	NIST Cybersecurity Framework (CSF)	MIT CSF 2020-2021 Audit	Active		06/22/2024	06/22/2024		Details

At the bottom, it shows 'Showing 1 to 5 of 5 entries' and navigation buttons: First, Previous, 1, Next, Last, Show All.

Figure 14: Active Audits — All 5 compliance audit tests active and scheduled in SimpleRisk Compliance Module

8. Conclusion

This GRC compliance audit of OpenSecure Bank against the NIST Cybersecurity Framework revealed a mixed security posture. While the bank has established foundational controls in the Identify, Protect, and Respond functions, critical gaps exist in the Detect and Recover functions that require immediate attention.

The three most pressing issues are the absence of SIEM monitoring, lack of MFA enforcement, and missing intrusion detection coverage. These gaps leave the bank unable to detect or respond to active threats in real time, significantly increasing the risk of a major security incident.

Of the 10 risks identified, 3 are rated High severity and require immediate remediation within 30 days. The highest risk, unauthorized access to the customer database with a score of 10, represents a critical threat to customer data confidentiality and regulatory compliance.

Implementing the Priority 1 remediation actions within 30 days will significantly reduce the bank's overall risk exposure and bring the Detect function into compliance with NIST CSF requirements. Full remediation of all findings is targeted for completion by December 22, 2026.

Overall Compliance Status: Partially Compliant

Overall Risk Posture: High

Recommended Next Audit Date: December 22, 2026

This report was prepared as part of a GRC compliance audit simulation using SimpleRisk. All data represents a fictional financial institution created for educational and portfolio demonstration purposes.
